

Ace Writeup by 菜叶片

ID	643
作者	ll104567
系统	Linux
难度	Baby

初始信息收集

端口扫描

端口号	服务
22	SSH
80	Apache httpd 2.4.62
8000	HTTPS

手动枚举信息

Port 80

后端Apache/2.4.62 (Debian) + PHP

/index.php是个静态页面 提示了用户名jiali

爆破web根目录扩展攻击面 发现/login.php

尝试多种登录绕过方法 均失败

Port 8000

页眉暴露web应用是Ajenti 以下是项目描述

Ajenti is a Linux & BSD modular server admin panel. Ajenti 2 provides a new interface and a better architecture, developed with [Python3](#) and [AngularJS](#).

从html源码 187-199行找到版本和插件信息等常量定义

```
187 <script>
188     angular.module('core').constant('urlPrefix', '');
189     angular.module('core').constant('ajentiPlugins', {'core': 'Core', 'ace': 'Ace editor', 'plugins': 'Plugins', 'dashboard': 'Dashboard', 'filesystem': 'Filesystem API', 'terminal': 'Terminal', 'packages': 'Packages',
'filemanager': 'File Manager', 'notepad': 'Notepad', 'passwd': 'User DB API', 'services': 'Services', 'settings': 'Settings'});
190     angular.module('core').constant('initialConfigContent', {'color': 'default', 'language': 'en', 'name': 'moban', 'session_max_time': 3600});
191     angular.module('core').constant('ajentiPlatform', 'debian gnu/linux');
192     angular.module('core').constant('ajentiPlatformUnmapped', 'debian gnu/linux');
193     angular.module('core').constant('ajentiVersion', '2.2.15');
194     angular.module('core').constant('devMode', 'False');
195     angular.module('core').constant('pwReset', 'False');
196     angular.module('core').constant('ajentiBootstrapColor', 'default');
197
198     angular.element(document).ready(ajentiBootstrap);
199 </script>
```

常量	值
版本号	2.2.15
开发模式	False
允许密码重置	False
插件	Core, Ace editor, Plugins, Dashboard...

这是较新版本的Ajenti 没有可用的公开漏洞 插件也没有相关漏洞

github issue #1520在26/5/28 15:01报告了新的需要认证的root身份任意文件写入0day漏洞

经测试 漏洞实际不存在 Ajenti FileSystem插件能上传文件到任意目录是刻意功能

权限隔离工作正常 即使Ajenti主进程为root身份 实际操作文件系统的worker进程为低权限用户

初步分析

两个web应用均需要认证且无法绕过 已得到用户名jiali 可以考虑爆破

Ajenti认证速度慢 可选择爆破效率更高的:80/login.php端点

Ajenti getshell

经爆破 我们得到了凭据 `jiali:qweasdzxc`

凭据复用 成功登录Ajenti

Ajenti作为Linux admin panel 允许我们以低权限用户jiali身份执行任意命令和操作文件系统

上传meterpreter shell 从web terminal设置权限 执行 反弹shell

Ajenti首选PAM认证 由此可知qwertyuiop也是jiali的系统密码 但是由于/etc/ssh/sshd_config最后一行的

DenyUsers jiali SSH密码认证和私钥认证均会失败

本地权限提升

信息收集

简单收集信息 没有发现配置错误(sudo 组 权限错误的特殊文件 suid二进制...)

也没有发现定时任务或其他在运行的服务

但是发现linux内核版本 `4.19.0-27` Debian发行版版本 `4.19.316-1 (2024-06-25)`

若相关内核模块没有被禁用 有多个内核漏洞可以利用

LPE via CopyFail

上传CopyFail python exploit 运行 成功getroot